

SYSCLIN

MANUAL DE SEGURIDAD

Políticas, controles y validaciones del sistema

Sistema SYSCLIN de gestión clínica
Versión 1.0
23/10/2026
Documento confidencial

CONTROL DEL DOCUMENTO

Campo	Valor
Documento	Manual de seguridad
Sistema	Sysclin, gestión clínica (agendamiento, consultorio, ventas)
Destinatario	Todo el personal, administrador y soporte técnico (ver «Cómo está organizado»)
Versión	1.0
Fecha de generación	23/10/2026
Revisión	Cada 6 meses, o después de un incidente o un cambio de infraestructura
Confidencialidad	Las Partes B a D describen controles de administración y no se entregan a los usuarios finales
Referencias	ISO/IEC 27002:2013; NIST SP 800-61 rev. 2 (respuesta a incidentes)

	Nombre	Firma	Fecha
Elaborado por			
Revisado por			
Aprobado por			

HISTORIAL DE REVISIONES

Versión	Fecha	Descripción del cambio
1.0	23/10/2026	Emisión inicial

ÍNDICE

1. Introducción.... 4
2. Cómo ingresar de forma segura.... 5
3. Su contraseña.... 6
4. Qué puede ver cada persona.... 9
5. Su sesión y su computadora.... 9
6. Cómo cuidar la información.... 9
7. Validación de los datos que se cargan.... 10
8. Si algo no está bien.... 13
9. Copias de respaldo.... 13
10. Calendario de tareas.... 14
11. Qué hacer ante un incidente.... 14
12. Reglas de validación por módulo.... 15
13. Objetivo, alcance y clasificación de la información.... 22
14. Seguridad de la aplicación.... 23
15. Auditoría y chequeo periódico.... 25
16. Riesgos aceptados y normativa.... 27
Anexo A. Preguntas frecuentes.... 28
Anexo B. Glosario.... 28
Anexo C. Contactos.... 29

1. Introducción

El sistema guarda **historias clínicas, datos personales de los pacientes y la facturación**. Es información sensible: si llega a manos equivocadas puede perjudicar a los pacientes y a la clínica. Por eso Sysclin tiene protecciones que funcionan solas y algunas reglas que dependen de cada persona que lo usa.

Este manual explica, sin términos técnicos, **qué hace el sistema para proteger los datos** y **qué debe hacer usted** para que esas protecciones funcionen. El uso de las pantallas lo explica el Manual de usuario, y la operación del servidor, el Manual de infraestructura.

1.1 Cómo está organizado

Capítulos	Para quién	Qué contienen
Cómo ingresar de forma segura, Su contraseña, Qué puede ver cada persona, Su sesión y su computadora, Cómo cuidar la información, Validación de los datos y Si algo no está bien	Todo el personal	Lo que debe hacer cada persona para que las protecciones funcionen
Copias de respaldo, Calendario de tareas y Qué hacer ante un incidente	Administrador	Tareas de seguridad de quien administra el sistema
Reglas de validación por módulo	Administrador y soporte técnico	Las reglas y los avisos que muestra el sistema en cada pantalla
Objetivo y alcance, Seguridad de la aplicación, Auditoría y Riesgos aceptados	Soporte técnico	Políticas y controles técnicos

Nota: Los recuadros **Nota** señalan reglas que hay que cumplir siempre; los recuadros **Advertencia**, acciones que pueden causar pérdida de datos o un problema de seguridad.

1.2 Lo que el sistema hace por usted

Estas protecciones están siempre activas; no tiene que hacer nada para que funcionen:

Protección	Qué significa en la práctica
Contraseñas protegidas	Las contraseñas se guardan cifradas. **Nadie puede verlas**, ni siquiera el administrador o el soporte técnico
Código por correo	Además de la contraseña, el sistema envía a su correo un código para entrar. Aunque alguien conozca su contraseña, sin su correo no puede ingresar
Bloqueo automático	Si alguien intenta adivinar su contraseña, la cuenta se bloquea 30 minutos después de 5 intentos; si sigue fallando, 1 hora; y después solo un administrador puede desbloquearla. Le llega un correo de aviso
Freno por equipo	Si desde un mismo equipo se fallan 10 ingresos en 15 minutos, el sistema frena los intentos desde ese equipo
Acceso por rol	Cada persona ve solo lo que necesita para su trabajo
Cierre automático	Si el sistema queda 20 minutos sin uso, cierra la sesión solo

Protección	Qué significa en la práctica
Registro de actividad	El sistema anota quién ingresó y quién creó, modificó o anuló cada dato, con fecha y hora. Ese registro no se puede modificar ni borrar
Nada se borra	Los usuarios se desactivan y los documentos importantes se anulan indicando el motivo, así siempre queda el historial. La historia clínica se conserva
Copias de respaldo	Cada 24 horas se guarda una copia cifrada de toda la información, y se conservan las de los últimos 14 días
Alertas al administrador	El sistema avisa por correo de las anulaciones y de los cambios hechos fuera del horario de atención, y envía un informe semanal los lunes

2. Cómo ingresar de forma segura

2.1 Los pasos para entrar

1. Abra el navegador e ingrese a la dirección del sistema que le dio el administrador.
2. Escriba su **usuario** y su **contraseña** y presione **Ingresar**.
3. Revise su correo: llega un **código de 6 números**. Escríbalo en la pantalla y presione **Verificar**. El código vale **5 minutos**.



Figura 2.1. *Pantalla para escribir el código de verificación*

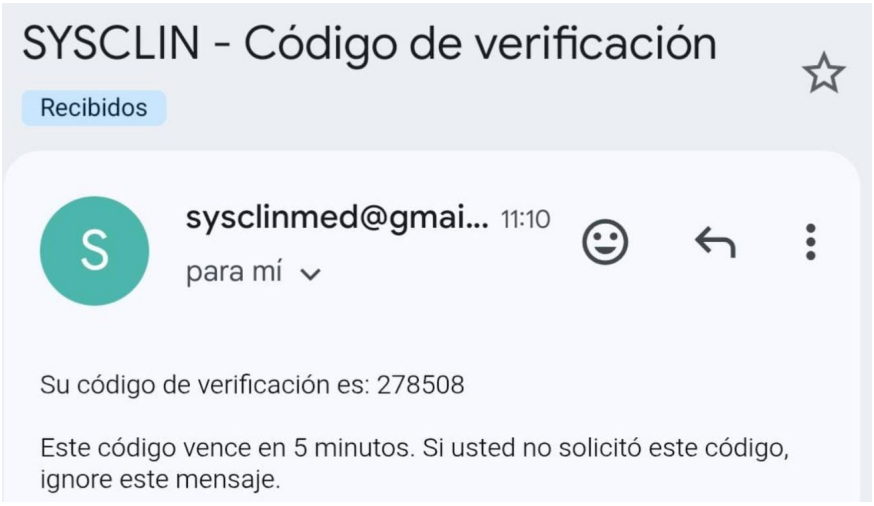


Figura 2.2. *Correo con el código de verificación*

La casilla **Recordarme en este equipo (30 días)** hace que el navegador recuerde solo su **nombre de usuario**; nunca guarda la contraseña. No la marque en una computadora compartida.

Cuando el código es correcto, el sistema recuerda ese equipo como **confiable** durante 60 días: en ese equipo no se lo vuelve a pedir. Por eso conviene ingresar solo desde su computadora de trabajo y nunca desde una compartida. Si ingresó desde un equipo ajeno, avise al administrador: puede revocar los equipos confiables de su cuenta.

2.2 ¿Por qué me pide un código?

Es una segunda llave. La contraseña es algo que usted **sabe**; el correo es algo que usted **tiene**. Para entrar hacen falta las dos, así que una contraseña robada, por sí sola, no alcanza. A esto se le llama **verificación en dos pasos**.

2.3 Reglas que conviene conocer

Situación	Qué pasa
Ingresa por primera vez con la contraseña temporal	El sistema le pide cambiarla antes de continuar (ver «Contraseña»)
Escribe mal el código	Tiene hasta 5 intentos con cada código. Después debe volver a ingresar para recibir uno nuevo
Pasan más de 5 minutos	El código vence. Vuelva a ingresar con su usuario y contraseña para recibir otro
Escribe mal la contraseña varias veces	La cuenta se bloquea 30 minutos después de 5 intentos; si sigue fallando, 1 hora; y después solo un administrador puede desbloquearla. El mensaje en pantalla indica hasta qué hora dura el bloqueo y le llega un correo de aviso
No llega el código	Espere un minuto y revise la carpeta de correo no deseado. Si no llega, vuelva a ingresar para pedir uno nuevo; si sigue sin llegar, avise al administrador

Nota: Si le llega un correo de **cuenta bloqueada** o un **código que usted no pidió**, alguien está intentando entrar con su usuario. Avise al administrador ese mismo día y cambie su contraseña.

3. Su contraseña

3.1 Qué debe tener

- Entre **8 y 16 caracteres**.
- Al menos una letra **mayúscula** y una **minúscula**.
- Al menos un **número**.

- Al menos un **símbolo** de este grupo: **! @ # $ % ^ & ***
- No puede ser igual a su nombre de usuario ni contener su nombre o su apellido.
- No puede ser una contraseña muy común, como las que aparecen en las listas de contraseñas más usadas.

La contraseña **vence cada 90 días**. Cuando venza, el sistema se lo avisa al ingresar y le pide elegir una nueva.

3.2 Cómo crear una fácil de recordar

Entre 8 y 16 caracteres alcanza con una frase corta. Piense en algo que solo usted sepa, junte las palabras y agregue un número y un símbolo:

Frase pensada	Contraseña resultante	¿Sirve?
Mi perro Toby	MiPerroToby#2026	Sí: tiene 16 caracteres, mayúsculas, minúsculas, número y símbolo
Consultorio	Consultorio123	No: no tiene símbolo y es fácil de adivinar
Su nombre y su fecha de nacimiento	Ana15031990!	No: contiene su nombre (el sistema la rechaza) y cualquiera que la conozca puede adivinarla

Nota: No use los ejemplos de este manual como contraseña. Cree la suya.

3.3 Cuidados

- **Nunca la comparta**, ni con compañeros ni con el administrador. Nadie de la clínica ni del soporte técnico se la va a pedir.
- No la anote en papeles pegados al monitor o al escritorio.
- No use la misma contraseña que en su correo, redes sociales o banco.
- Si usa una computadora compartida, no acepte que el navegador recuerde la contraseña.
- Cámbiela **apenas sospeche** que otra persona la conoce.

3.4 Primer ingreso: cambio obligatorio

Cuando el administrador crea su usuario o le restablece la contraseña, le entrega una **contraseña temporal**. Al ingresar con ella, el sistema no lo deja pasar: muestra la pantalla **«Cambie su contraseña»**.

1. Escriba la **Contraseña actual (temporal)**.
2. Escriba la **Nueva contraseña** y repítala en **Repita la nueva contraseña**. Debe cumplir las reglas de arriba y ser distinta de la temporal.
3. Presione **Cambiar contraseña** y vuelva a ingresar con la nueva.

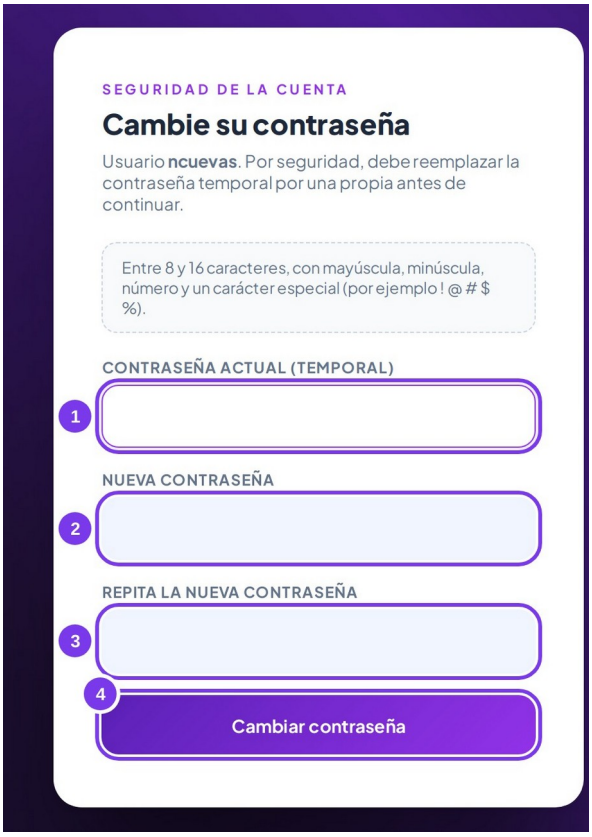


Figura 3.1. *Pantalla «Cambie su contraseña»: ① contraseña temporal ② nueva ③ repetición ④ Cambiar contraseña*

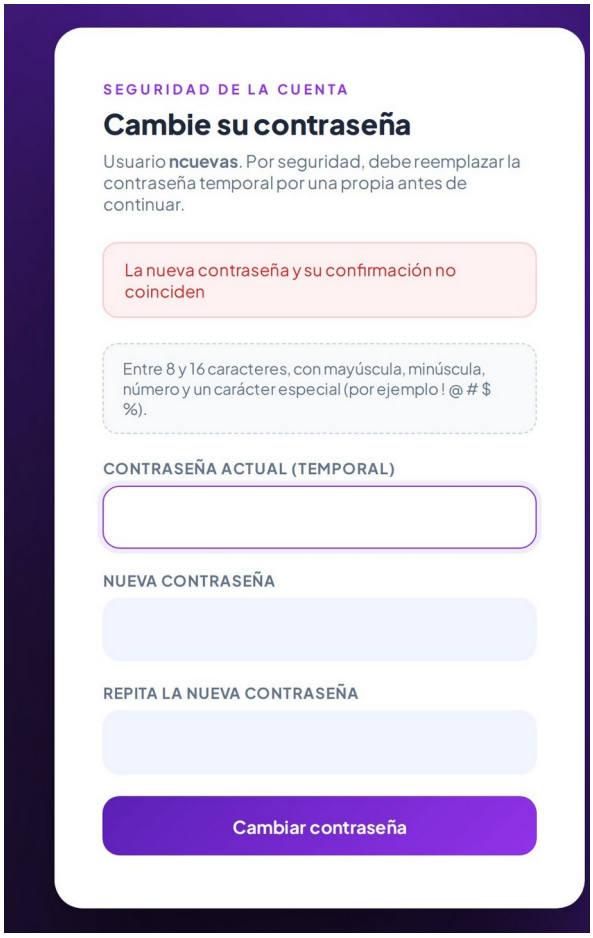


Figura 3.2. *Aviso cuando la nueva contraseña y su repetición no coinciden*

Así la contraseña definitiva solo la conoce usted. El cambio queda registrado en la auditoría, sin guardar la contraseña.

3.5 Si olvidó su contraseña o necesita cambiarla

1. En la pantalla de ingreso, haga clic en **¿Olvidaste tu contraseña?**.
2. Escriba su **Usuario** y el **Correo vinculado a su cuenta**, y presione **Enviar enlace**.
3. Abra el enlace que llega a su correo. Vale **24 horas** y se puede usar **una sola vez**.
4. Escriba la **Nueva contraseña**, repítala en **Confirmar contraseña** y presione **Guardar contraseña**. Ingrese con la nueva.

Por seguridad, el sistema responde lo mismo exista o no el usuario, y envía como máximo 3 correos por cuenta cada hora.

4. Qué puede ver cada persona

Cada usuario tiene un **rol** según su función. El menú muestra solo las pantallas que ese rol tiene permitidas y, dentro de algunas pantallas, el rol puede tener permitido o no crear, editar o anular. Así cada persona accede únicamente a la información que necesita para su trabajo.

Rol	Trabaja principalmente con
Recepción	Pacientes, agenda médica, citas y lista de espera, además de los reportes y la auditoría de agendamiento
Clínico	Su agenda, consultas, historia clínica, PEI y fichas médicas; la agenda médica en solo lectura; sus propios cambios en la auditoría
Ventas	Pedidos, presupuestos, caja, facturas, remisiones, notas de crédito y débito, cuentas a cobrar, cobranzas, recaudaciones y libro de ventas
Administrador	Todo lo anterior, más usuarios, funcionarios, permisos, menú, catálogos, timbrados y puntos de expedición
Superadministrador	La configuración técnica del sistema y la baja de usuarios. No participa de la gestión clínica

Los permisos exactos de cada rol los define el administrador y pueden cambiar. En **Ventas**, además, solo el Administrador y el Superadministrador pueden anular documentos.

> **Nota:** Si no ve una opción que necesita para su trabajo, pídasela al administrador. Es normal: el sistema muestra solo lo permitido para su rol.

5. Su sesión y su computadora

- **Cierre la sesión al terminar**: haga clic en su nombre, arriba a la derecha, y elija **Cerrar Sesión**.
- Si se levanta de la computadora, aunque sea un momento, **bloquéela** con las teclas **Windows + L**. Para volver, ingrese la clave de Windows.
- Si se olvida, el sistema cierra la sesión solo después de **20 minutos sin uso**, y en todo caso una sesión dura como máximo 60 minutos. Lo que ya guardó no se pierde; lo que estaba escribiendo y no guardó, sí.
- El sistema permite **una sola sesión abierta por usuario**: no use su usuario en dos equipos a la vez ni deje que otra persona lo use.
- No deje la pantalla con datos de pacientes a la vista de las personas que esperan en recepción.

6. Cómo cuidar la información

6.1 Un usuario por persona

Cada persona debe usar **solo su propio usuario**. El sistema registra quién hace cada operación: si alguien usa su usuario, todo lo que haga queda registrado a su nombre.

6.2 Datos que no se deben cargar

- Contraseñas, claves ni datos personales que no correspondan, en los campos de observaciones.
- Números completos de tarjetas de crédito o débito, ni su código de seguridad: el sistema no los necesita.

6.3 Informes y documentos

- Los informes exportados a PDF o Excel, las facturas y las recetas contienen datos de pacientes. No los envíe por WhatsApp ni a correos personales, y no los guarde en pendrives propios.
- Borre los archivos descargados cuando ya no los necesite.
- Los papeles impresos con datos de pacientes no van a la basura común: rómpalos o guárdelos.

6.4 Correos falsos

El sistema solo le envía tres tipos de correo:

- El **código de verificación**, cuando usted inicia sesión.
- El **enlace para cambiar la contraseña**, cuando usted lo pide.
- El **aviso de cuenta bloqueada**.

A los administradores, además, les llegan las alertas de anulaciones y de cambios fuera de horario, y el informe semanal.

> **Nota:** El sistema **nunca** le va a pedir su contraseña por correo, mensaje o teléfono. Si recibe un pedido así, es un intento de engaño: no responda, no haga clic en ningún enlace y avise al administrador.

6.5 Todo queda registrado

El sistema anota los ingresos (correctos y fallidos) y cada alta, modificación o anulación de datos, con el usuario, la fecha y la hora. Las facturas, las órdenes y otros registros importantes no se borran: se **anulan** indicando un motivo. Revise bien antes de confirmar una anulación.

7. Validación de los datos que se cargan

Antes de guardar, el sistema revisa cada dato. Si algo no cumple una regla, **no se guarda nada** y aparece un aviso que dice qué corregir; lo que ya estaba escrito no se pierde. Los avisos son de pocos tipos y dicen lo mismo en todas las pantallas.

7.1 Cómo se controla: tres capas

Capa	Qué hace
1. En la pantalla	Revisa los datos al presionar Guardar y avisa al instante. Es una ayuda para el usuario, pero no alcanza sola
2. En el servidor	Vuelve a revisar **todos** los datos, aunque la pantalla ya lo haya hecho. Es el control que no se puede saltear
3. En la base de datos	Controla los campos obligatorios y los valores únicos, como la cédula. Las consultas son **parametrizadas**: el dato nunca se mezcla con la instrucción SQL, lo que impide la inyección SQL. Además, todo formulario lleva protección contra formularios falsificados (CSRF)

7.2 Tipos de aviso

Tipo	Cuándo aparece	Ejemplo del mensaje	Qué hacer
Campo obligatorio	Dejó vacío un dato que el sistema necesita para guardar.	El campo "Descripción" es obligatorio.	Complete el campo que nombra el aviso y presione Guardar de nuevo.
Caracteres no permitidos	El dato trae símbolos o un formato que ese campo no admite.	El campo "Descripción" contiene caracteres no permitidos. Use solo letras, números y espacios.	Quite los símbolos; el aviso indica qué sí se puede escribir en ese campo.
El dato ya existe	Ese dato ya está cargado y no se puede repetir.	Ya existe una especialidad "PSICOLOGÍA".	Búsquelo en el listado y edítelo, o use otro valor.
Valor fuera de lo permitido	El número o la fecha no cumple la condición de la operación.	El fin del bloqueo debe ser posterior al inicio.	Corrija el valor según lo que indica el aviso.
Operación no permitida en este momento	El registro está en un estado que no admite esa acción (por ejemplo, ya anulado o con la caja cerrada).	Una cita en estado 'Confirmada' no puede pasar a 'COMPLETADA'.	Revise el estado del registro; el aviso explica qué falta resolver antes.

Un aviso que no encaja en ninguno de estos tipos es una regla propia de la pantalla (por ejemplo, una cita sin turno libre o una caja que no está abierta). El aviso siempre dice qué falta.

7.3 Cómo se ven los avisos

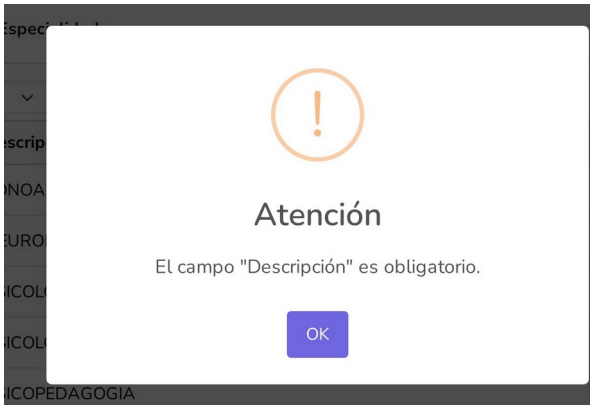


Figura 7.1. *Campo obligatorio: Especialidades*

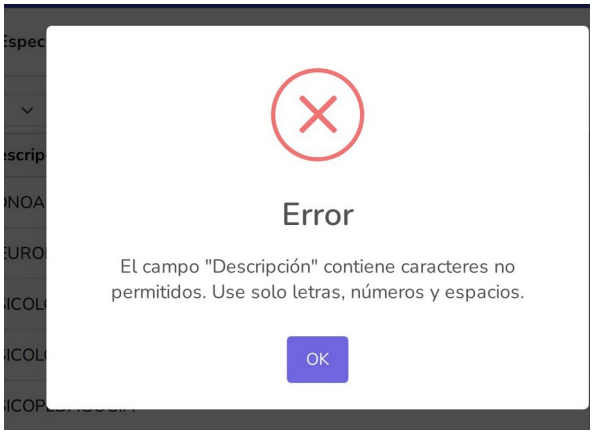


Figura 7.2. *Caracteres no permitidos: Especialidades*



Figura 7.3. *El dato ya existe: Especialidades*

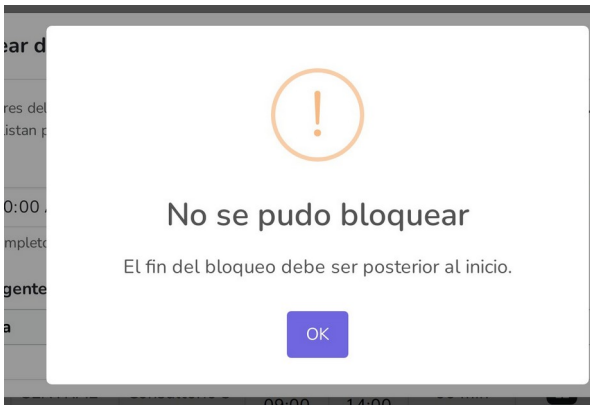


Figura 7.4. *Valor fuera de lo permitido: Agenda Médica (bloqueo de días)*

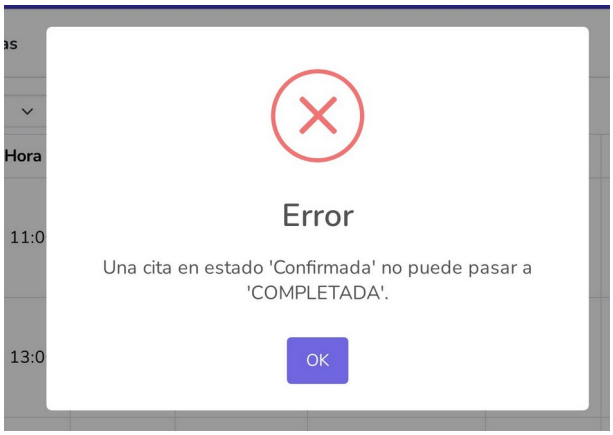


Figura 7.5. *Operación no permitida en este momento: Citas (cambio de estado)*

Las reglas y los avisos de cada pantalla, módulo por módulo, están en el capítulo «Reglas de validación por módulo».

8. Si algo no está bien

Situación	Qué hacer
Me llegó un código o un aviso de bloqueo que yo no pedí	Avise al administrador ese mismo día y cambie su contraseña
Creo que alguien conoce mi contraseña	Cámbiela de inmediato con **¿Olvidaste tu contraseña?** y avise al administrador
Mi cuenta está bloqueada	Espere: el primer bloqueo dura 30 minutos y el segundo, 1 hora. Si el bloqueo no se levanta o no fue usted quien se equivocó, avise al administrador
Veo datos o movimientos que yo no cargué con mi usuario	No los modifique. Avise al administrador para que revise el registro de actividad
Recibí un correo o una llamada pidiendo mi contraseña	No responda ni haga clic en enlaces. Avise al administrador
Perdí el acceso a mi correo	Avise al administrador: sin su correo no recibe los códigos y no puede ingresar hasta que el administrador revoque la verificación en dos pasos y vincule otro correo
La computadora se comporta de forma extraña (ventanas raras, lentitud repentina)	Cierre la sesión, no siga trabajando en ella y avise

Nota: Ante la duda, avise. Un aviso a tiempo evita problemas mayores, y nadie va a culpar a quien reporta algo que resultó no ser grave.

9. Copias de respaldo

Una copia de respaldo es una copia de toda la información del sistema, guardada aparte. Si el servidor se rompe, lo roban o los datos se dañan, con la copia se recupera todo hasta un día antes como máximo.

9.1 Cómo funciona

- Se hace **automáticamente cada 24 horas**, y una más cada vez que arranca el servicio de respaldo.
- Cada copia se guarda **cifrada**: sin la clave privada nadie puede leerla, ni siquiera quien se lleve el servidor.
- Se conservan las copias de los **últimos 14 días**; las más viejas se borran solas.
- Antes de cada migración, actualización o despliegue, el soporte técnico hace además una copia manual.

9.2 Lo que depende de usted

- **La clave privada de respaldo y su contraseña.** Guárdelas por separado y fuera del servidor (por ejemplo, un USB y un gestor de contraseñas). Sin ellas, ninguna copia se puede recuperar. Conviene tener dos copias de la clave privada en lugares distintos.
- **Una copia fuera del equipo.** Se recomienda copiar los respaldos una vez por semana a un disco externo o a la nube. Como están cifrados, pueden guardarse en la nube sin exponer datos.
- **La prueba de restauración.** Pida al soporte técnico que pruebe la recuperación de una copia **una vez por mes**, y antes de cada entrega o despliegue.

Nota: Una copia que nunca se probó no se sabe si sirve. La prueba de restauración se hace sobre una base de prueba y no toca los datos reales.

Los comandos para hacer una copia manual, probar y restaurar están en el Manual de infraestructura, capítulo «Backups y restauración».

10. Calendario de tareas

Cuándo	Tarea	Quién
Cuando alguien deja de trabajar en la clínica	Pedir al Superadministrador que desactive su usuario	Administrador
Cada vez que llega un correo de cuenta bloqueada	Revisar en Auditoría si los intentos fueron de la propia persona, antes de desbloquear	Administrador
Cada vez que llega una alerta por correo	Revisar la anulación o el cambio fuera de horario que se informa	Administrador
Cada lunes	Leer el informe semanal de auditoría (llega por correo a las 07:00)	Administrador
Cada semana (recomendado)	Copiar los respaldos a un disco externo o a la nube	Administrador o soporte técnico
Cada mes	Chequeo de seguridad periódico (lista del capítulo «Auditoría y chequeo periódico»)	Soporte técnico
Cada mes	Revisar los bloqueos repetidos de una misma cuenta y las ráfagas de intentos fallidos desde un mismo equipo	Administrador
Cada mes	Prueba de restauración de una copia de respaldo	Soporte técnico
Cada 60 días	Renovar el certificado de HTTPS del servidor	Soporte técnico
Cada 90 días	Cambiar la contraseña: el sistema la vence y la pide	Todo el personal
Cada 6 meses	Cambiar las contraseñas de servicio de la base de datos (la de la aplicación y la del administrador de la base)	Soporte técnico
Cada 6 meses, o después de un incidente	Revisar este manual y que cada usuario activo siga trabajando en la clínica	Administrador

El detalle técnico de cada tarea del soporte está en el Manual de infraestructura y en los últimos capítulos de este manual.

11. Qué hacer ante un incidente

Un incidente es cualquier situación en la que la información pudo quedar expuesta o dañada: un acceso que nadie reconoce, una contraseña revelada, una computadora robada, datos borrados o modificados sin explicación, o el sistema caído.

1. **Frenar:** en el detalle del usuario afectado (pantalla Usuarios), cierre sus sesiones y revoque su verificación en dos pasos. Si hay que desactivar la cuenta, pídaselo al Superadministrador.
2. **Avisar:** comuníquese con el soporte técnico lo antes posible.
3. **Revisar:** con Auditoría, identifique qué se hizo, cuándo y desde qué equipo.
4. **Recuperar:** si se dañaron datos, el soporte técnico restaura la última copia de respaldo.
5. **Registrar:** anote la fecha, qué pasó, qué datos se vieron afectados y qué se hizo.

Fecha	Qué pasó	Datos afectados	Acciones tomadas

Advertencia: Si se robó o se perdió la computadora del servidor, avise al soporte técnico de inmediato: hay que cambiar las claves internas del sistema, lo que además cierra todas las sesiones abiertas.

Las fases, los casos frecuentes y los comandos están en el capítulo «Respuesta a incidentes».

12. Reglas de validación por módulo

Por cada módulo hay dos tablas. La primera resume, pantalla por pantalla, los datos que no pueden quedar vacíos, los valores que no se pueden repetir y los caracteres que admite cada campo. La segunda lista los avisos propios de cada regla, sin repetirlos aunque aparezcan en varias pantallas. Los tipos de aviso y sus capturas están en el capítulo «Validación de los datos que se cargan».

12.1 Personas

Pantalla	Campos obligatorios	Valor único	Caracteres que admite
Funcionarios	Apellido, Cargo, Cédula, Nombre, Teléfono	Sí	
Pacientes	Apellido, Cédula, Fecha de nacimiento, Nombre	Sí	
Usuarios	Contraseña, Funcionario, Rol, Username		

Aviso propio de la regla	Pantalla
Debe indicar el número de RUC.	Pacientes
Debe seleccionar al menos una especialidad	Funcionarios
Debe seleccionar al menos una especialidad.	Funcionarios
El nombre y el apellido solo pueden contener letras, espacios, guion y apóstrofe.	Funcionarios, Pacientes
Faltan campos obligatorios: nombre, apellido, cédula y fecha de nacimiento.	Pacientes
La matrícula es obligatoria para especialistas.	Funcionarios
Las contraseñas no coinciden.	Usuarios
Matrícula es obligatoria para especialistas	Funcionarios
No se pudo actualizar el paciente.	Pacientes
No se pudo actualizar el usuario. Verifique que el username no esté en uso.	Usuarios
No se pudo crear el paciente.	Pacientes
No se pudo crear el usuario. Verifique que el username no exista o que el funcionario no tenga ya un usuario asignado.	Usuarios
No se pudo resetear los intentos.	Usuarios
Tipo de documento inválido. Debe ser CI o RUC.	Pacientes
… tiene … cita(s) pendiente(s) (próxima: …). Cancélelas o reagéndelas con otro especialista antes de darlo de baja.	Funcionarios

12.2 Agendamiento

Pantalla	Campos obligatorios	Valor único	Caracteres que admite
Agenda Medica	Motivo del bloqueo	Sí	
Citas	Motivo, Motivo de la corrección, Paciente, Turno	Sí	
Lista de Espera	Horario, Paciente		

Aviso propio de la regla	Pantalla
'En consulta' se registra con 'Iniciar consulta', no con una corrección.	Agenda Medica, Citas
Debe seleccionar al menos una especialidad	Agenda Medica, Citas
El bloqueo tiene que terminar en el futuro.	Agenda Medica
El especialista no tiene agendas cargadas.	Agenda Medica
El especialista no tiene esa especialidad	Agenda Medica, Citas
El fin del bloqueo debe ser posterior al inicio.	Agenda Medica
El motivo de la corrección es obligatorio.	Agenda Medica, Citas
El paciente no tiene teléfono registrado.	Citas
El slot indicado no existe	Agenda Medica, Citas
El slot ya no está disponible	Agenda Medica, Citas
El sobreturno tiene que ser en el futuro.	Agenda Medica
El turno de esta cita ya no está libre (lo tomó otra cita o se quitó de la agenda). Agende una cita nueva.	Agenda Medica, Citas
El turno indicado no existe	Agenda Medica, Citas
El turno seleccionado no corresponde al especialista de la cita	Agenda Medica, Citas
El turno seleccionado ya no está disponible	Agenda Medica, Citas
El turno seleccionado ya pasó; elija un turno futuro	Agenda Medica, Citas
Ese día el especialista no atiende en esta agenda.	Agenda Medica
Ese horario está bloqueado (…).	Agenda Medica
Estado '…' no encontrado	Agenda Medica, Citas
Estado inválido. Valores permitidos: ….	Citas, Lista de Espera
Indique la fecha y hora de inicio y de fin del bloqueo.	Agenda Medica
Indique la fecha y la hora del sobreturno.	Agenda Medica
La agenda está desactivada.	Agenda Medica
La agenda indicada no existe.	Agenda Medica
La agenda no permite sobreturnos: configure el % de sobreturnos en la agenda.	Agenda Medica
La cita indicada no existe	Agenda Medica, Citas
La cita sigue abierta: use las acciones normales (Editar o cambiar estado).	Agenda Medica, Citas
La fecha está fuera de la vigencia de la agenda.	Agenda Medica
Matrícula es obligatoria para especialistas	Agenda Medica, Citas
No hay cambios para guardar.	Agenda Medica, Citas
No se puede editar una cita en estado '…'	Agenda Medica, Citas
Seleccione el especialista.	Agenda Medica
Ya se usaron los … sobreturno(s) permitidos para ese día.	Agenda Medica

Aviso propio de la regla	Pantalla
… tiene … cita(s) pendiente(s) (próxima: …). Cancélelas o reagéndelas con otro especialista antes de darlo de baja.	Agenda Medica, Citas

12.3 Clínico

Pantalla	Campos obligatorios	Valor único	Caracteres que admite
Consultas	Descripción del tratamiento, Diagnóstico, Especialidad de destino, Estado de la consulta, Fecha de inicio, Fecha de la consulta, Fecha de la orden, Fecha de la receta, Fecha del certificado, Insumo, Motivo de derivación, Motivo de la consulta, Motivo del certificado, Signo, Síntoma, Tipo de certificado, Tipo de procedimiento, Tipo de tratamiento	Sí	

Aviso propio de la regla	Pantalla
'En consulta' se registra con 'Iniciar consulta', no con una corrección.	Consultas
Cada ítem debe indicar tipo ESTUDIO o ANALISIS.	Consultas
Debe seleccionar al menos una especialidad	Consultas
El contenido de la nota no puede estar vacío.	Fichas Medicas
El especialista no tiene esa especialidad	Consultas
El informante debe ser uno de: ….	Consultas
El motivo de la corrección es obligatorio.	Consultas
El slot indicado no existe	Consultas
El slot ya no está disponible	Consultas
El turno de esta cita ya no está libre (lo tomó otra cita o se quitó de la agenda). Agende una cita nueva.	Consultas
El turno indicado no existe	Consultas
El turno seleccionado no corresponde al especialista de la cita	Consultas
El turno seleccionado ya no está disponible	Consultas
El turno seleccionado ya pasó; elija un turno futuro	Consultas
Estado '…' no encontrado	Consultas
Estado inválido. Debe ser ACTIVO o CERRADO.	PEI
Indique la dosis en cada ítem.	Consultas
Indique la frecuencia en cada ítem.	Consultas

Aviso propio de la regla	Pantalla
La cantidad debe ser mayor a cero.	Consultas
La cita indicada no existe	Consultas
La cita sigue abierta: use las acciones normales (Editar o cambiar estado).	Consultas
La orden debe tener al menos un ítem de estudio o análisis.	Consultas
La receta debe tener al menos un medicamento.	Consultas
Matrícula es obligatoria para especialistas	Consultas
No hay cambios para guardar.	Consultas
No se pudo determinar el especialista. Verificá tu perfil.	PEI, Fichas Medicas
No se puede editar una cita en estado '…'	Consultas
No se puede iniciar una consulta para una cita en estado "…".	Consultas
Seleccione el medicamento en cada ítem.	Consultas
Seleccione el tipo de análisis en cada ítem.	Consultas
Seleccione el tipo de estudio en cada ítem.	Consultas
Stock insuficiente para registrar este insumo.	Consultas
… tiene … cita(s) pendiente(s) (próxima: …). Cancélelas o reagéndelas con otro especialista antes de darlo de baja.	Consultas

12.4 Ventas

Pantalla	Campos obligatorios	Valor único	Caracteres que admite
Pedidos	Fecha del pedido, Paciente		
Presupuestos	Fecha del presupuesto, Paciente		
Estado de Caja	Caja, Saldo final, Usuario		
Historial de Caja	Caja, Saldo final, Usuario		
Arqueos de Caja	Apertura de caja, Caja, Monto real		
Facturas	Condición de venta, Estado de la factura, Fecha de la factura, Paciente, Precio de cada ítem, Punto de expedición, Timbrado, Tipo de comprobante		
Remisiones	Fecha de la remisión, Paciente		
Notas de Credito	Factura, Motivo		
Notas de Debito	Factura, Motivo		
Cobranzas	Caja, Cuenta a cobrar, Factura		
Recaudaciones	Caja, Depósito, Fecha de depósito		

Aviso propio de la regla	Pantalla
'En consulta' se registra con 'Iniciar consulta', no con una corrección.	Presupuestos
Cada línea de detalle requiere una forma de cobro.	Cobranzas
Cada ítem debe tener una cantidad mayor a 0.	Pedidos, Presupuestos
Cada ítem debe tener una descripción.	Pedidos, Presupuestos, Facturas, Remisiones, Notas de Credito, Notas de Debito
Cobranza no encontrada.	Cobranzas
Debe agregar al menos una forma de cobro.	Cobranzas
Debe indicar el motivo de la anulación.	Facturas
El descuento no puede ser negativo ni mayor al total de la factura.	Facturas, Notas de Credito, Notas de Debito
El especialista no tiene esa especialidad	Presupuestos
El monto de cada forma de cobro debe ser mayor a 0.	Cobranzas
El monto total cobrado debe ser mayor a cero.	Cobranzas
El monto total de la recaudación debe ser mayor a cero.	Recaudaciones
El monto total debe ser mayor a cero.	Recaudaciones
El motivo de la corrección es obligatorio.	Presupuestos
El pedido debe tener al menos un ítem.	Pedidos
El plan de tratamiento (PEI) indicado no corresponde al paciente.	Presupuestos
El presupuesto debe tener al menos un ítem.	Presupuestos
El slot indicado no existe	Presupuestos
El slot ya no está disponible	Presupuestos
El turno de esta cita ya no está libre (lo tomó otra cita o se quitó de la agenda). Agende una cita nueva.	Presupuestos
El turno indicado no existe	Presupuestos
El turno seleccionado no corresponde al especialista de la cita	Presupuestos
El turno seleccionado ya no está disponible	Presupuestos
El turno seleccionado ya pasó; elija un turno futuro	Presupuestos
Elija la forma de cobro de la factura al contado.	Facturas, Notas de Credito, Notas de Debito
Esta cuenta ya está completamente cobrada.	Cobranzas
Estado '…' no encontrado	Presupuestos
Estado inválido.	Pedidos, Presupuestos
La caja elegida no está abierta. Ábrala en Estado de Caja antes de facturar al contado.	Facturas
La caja y el depósito son obligatorios.	Recaudaciones
La caja ya tiene una apertura activa (ID …).	Estado de Caja, Historial de Caja, Facturas
La cantidad de cada ítem debe ser mayor a 0.	Facturas, Remisiones
La cita indicada no existe	Presupuestos
La cita sigue abierta: use las acciones normales (Editar o cambiar estado).	Presupuestos
La cobranza debe tener al menos una forma de cobro.	Cobranzas
La cobranza ya está anulada o no se encontró.	Cobranzas
La cuenta a cobrar está anulada (la factura fue anulada).	Cobranzas
La cuenta a cobrar no existe.	Cobranzas

Aviso propio de la regla	Pantalla
La cuenta a cobrar, la factura y la caja son obligatorias.	Cobranzas
La factura debe tener al menos un ítem en el detalle.	Facturas, Notas de Credito, Notas de Debito
La factura indicada no existe.	Notas de Credito, Notas de Debito
La factura ya está anulada o no se pudo anular.	Facturas
La moneda de la caja no coincide con la de la cuenta a cobrar.	Cobranzas
La nota de crédito debe tener al menos un ítem.	Notas de Credito
La nota de débito debe tener al menos un ítem.	Notas de Debito
La nota ya está anulada o no se pudo anular.	Notas de Credito, Notas de Debito
La recaudación ya está anulada o no se encontró.	Recaudaciones
La remisión debe tener al menos un ítem en el detalle.	Remisiones
La remisión ya está anulada.	Remisiones
La remisión ya fue entregada o no se puede cambiar su estado.	Remisiones
Las formas de cobro deben sumar el total de la factura.	Facturas, Notas de Credito, Notas de Debito
Monto fuera de rango para numero_a_letras: …	Facturas, Notas de Credito, Notas de Debito
No hay caja abierta. Debe abrir la caja antes de registrar una cobranza.	Cobranzas
No hay caja abierta. Debe abrir la caja antes de registrar una recaudación.	Recaudaciones
No hay cambios para guardar.	Presupuestos
No se encontró el presupuesto.	Presupuestos
No se encontró la apertura de caja especificada.	Arqueos de Caja
No se pudo marcar como depositada.	Recaudaciones
No se puede editar una cita en estado '…'	Presupuestos
Para facturar al contado elija la caja donde entra el cobro.	Facturas, Notas de Credito, Notas de Debito
Punto de expedición no encontrado.	Facturas, Notas de Credito, Notas de Debito
Recaudación no encontrada.	Recaudaciones
Solo se puede convertir en pedido un presupuesto aprobado.	Presupuestos
Solo se pueden depositar recaudaciones en estado PENDIENTE.	Recaudaciones

12.5 Configuración

Pantalla	Campos obligatorios	Valor único	Caracteres que admite
Cajas	Descripción	Sí	letras, números, espacios, puntos y guiones
Cargos	Descripción	Sí	letras, números y espacios
Condiciones de Venta	Descripción	Sí	letras, números, espacios y puntos
Consultorios	Descripción, Sede	Sí	letras, números y espacios

Pantalla	Campos obligatorios	Valor único	Caracteres que admite
Depósitos	Descripción	Sí	letras, números, espacios, puntos y guiones
Diagnósticos	Descripción	Sí	letras, números, espacios y puntos
Empresa		Sí	
Entidades Adheridas	Descripción	Sí	letras, números, espacios, puntos y guiones
Entidades Emisoras	Descripción	Sí	letras, números, espacios, puntos y guiones
Especialidades	Descripción	Sí	letras, números y espacios
Estados de Factura	Descripción	Sí	letras, números, espacios y puntos
Formas de Cobro	Código, Descripción	Sí	letras, números, espacios y puntos
Instrumentos	Descripción	Sí	letras, números, espacios y puntos
Insumos	Descripción	Sí	letras, números, espacios y puntos
Ítems / Servicios	Descripción, Tipo de ítem	Sí	letras, números, espacios, puntos y guiones
Marcas de Tarjeta	Descripción	Sí	letras, números, espacios y puntos
Medicamentos	Descripción	Sí	letras, números, espacios y puntos
Monedas	Código, Descripción	Sí	letras, números, espacios y puntos
Sedes	Descripción	Sí	letras, números y espacios
Signos	Descripción	Sí	letras, números, espacios y puntos
Síntomas	Descripción	Sí	letras, números, espacios y puntos
Tipos de Análisis	Descripción	Sí	letras, números, espacios y puntos
Tipos de Certificado Médico	Descripción	Sí	letras, números, espacios y puntos
Tipos de Comprobante	Descripción	Sí	letras, números, espacios y puntos
Tipos de Estudio	Descripción	Sí	letras, números, espacios y puntos
Tipos de Impuesto	Descripción	Sí	letras, números, espacios, puntos y el símbolo %
Tipos de Ítem	Descripción	Sí	letras, números, espacios y puntos
Tipos de Procedimiento	Descripción	Sí	letras, números, espacios y puntos

Pantalla	Campos obligatorios	Valor único	Caracteres que admite
Tipos de Tratamiento	Descripción	Sí	letras, números, espacios y puntos
Timbrados	Fechas, Fechas de inicio y vencimiento, Número de timbrado	Sí	
Puntos de Expedicion	Código, Nombre, Nombre del punto, Timbrado	Sí	

Aviso propio de la regla	Pantalla
Cada cambio debe incluir id_modulo, id_accion y permitido.	Roles y Permisos
Cada cambio debe incluir id_pagina y visible.	Menu
El cargo "…" está reservado por el sistema.	Cargos
El código CIE-10 no tiene un formato válido (ej. F32 o F32.1).	Diagnósticos
El código de establecimiento SIFEN debe tener 3 dígitos numéricos.	Sedes
El código de establecimiento debe tener 3 dígitos numéricos.	Timbrados
El código debe tener 3 dígitos numéricos.	Puntos de Expedicion
El código es obligatorio (3 dígitos).	Puntos de Expedicion
El estado de caja debe ser uno de: ….	Cajas
El número de timbrado debe tener 8 dígitos numéricos.	Timbrados
El precio unitario no puede ser negativo.	Insumos
El saldo inicial no puede ser negativo.	Cajas
El stock actual no puede ser negativo.	Insumos
El stock mínimo no puede ser negativo.	Insumos
El tipo de depósito debe ser uno de: ….	Depósitos
La fecha de vencimiento debe ser mayor o igual a la de inicio.	Timbrados
Las fechas no tienen un formato válido.	Auditoria
No hay una empresa configurada. Configure los datos de la empresa antes de crear sedes.	Sedes
No se pudo cerrar la sesión	Auditoria
No se puede eliminar: tiene facturas asociadas.	Timbrados, Puntos de Expedicion
No se recibieron cambios para guardar.	Roles y Permisos, Menu

13. Objetivo, alcance y clasificación de la información

Este manual reúne **las políticas y los controles de seguridad** de Sysclin: contraseñas y autenticación, roles y control de acceso, seguridad de la aplicación, auditoría y respuesta ante un incidente.

Los procedimientos de operación del servidor (contenedores, configuración, base de datos, despliegue y backups) están en el **Manual de infraestructura**. El trabajo diario de cada rol en agenda, consultorio y ventas lo explica el **Manual de usuario** (botón de Ayuda).

13.1 Objetivo

- **Confidencialidad**: solo accede quien debe.
- **Integridad**: los datos no se alteran sin control y queda registro de los cambios.
- **Disponibilidad**: el sistema funciona y, si algo falla, se recupera desde un backup.

13.2 Alcance

Alcanza a la aplicación web, la base de datos, los respaldos, la infraestructura donde corre (desarrollo y servidor) y a todas las personas que usan o administran el sistema.

13.3 Convenciones de este manual

- Los comandos se ejecutan en **PowerShell**, desde la **carpeta raíz del proyecto** (syscomcli), salvo que se indique otra cosa. Los marcados como bash son para el servidor Linux.
- Donde aparece <algo>, se reemplaza por el valor real, sin los signos < >.
- El texto que empieza con **Nota:** es información a tener en cuenta; el que empieza con **Advertencia:**, una acción que puede causar pérdida de datos o corte del servicio.

13.4 Clasificación de la información

Nivel	Qué incluye	Exigencias
Sensible	Historia clínica (consultas, diagnósticos, recetas, PEI, derivaciones), datos personales de pacientes, credenciales	Acceso solo por rol; cifrado en tránsito y en los respaldos; auditoría de acceso; **no se borra físicamente** (la historia clínica se conserva)
Interna	Facturación, caja, cobranzas, agenda, configuración	Acceso por rol; cifrado en tránsito y en los respaldos
Pública	Pantalla de inicio de sesión, guía de uso	Sin restricción

Nota: Como se trata de datos de salud, **el cifrado, el respaldo y la auditoría tienen prioridad sobre la comodidad**.

14. Seguridad de la aplicación

14.1 SECRET_KEY

- Firma la cookie de sesión de cada usuario.
- **La aplicación no arranca** si falta o tiene menos de 32 caracteres; el log muestra RuntimeError: SECRET_KEY ausente o con menos de 32 caracteres en .env.
- Cambiarla cierra la sesión de todos los usuarios. Hacerlo si se sospecha que se filtró.
- En el servidor tiene que ser **distinta** de la de desarrollo.

14.2 Cookie de sesión

```
curl.exe -sk -D - -o NUL https://localhost/login | Select-String 'Set-Cookie'
```

Atributo	Protege contra	Dónde
HttpOnly	Robo de la sesión con JavaScript	Siempre
SameSite=Lax	Peticiones falsificadas desde otros sitios	Siempre
Secure	Envío de la cookie por HTTP sin cifrar	Servidor (SESSION_COOKIE_SECURE=1)

Además, todo formulario lleva protección **CSRF**.

14.3 Modo depuración

Advertencia: FLASK_DEBUG=1 activa el depurador, que permite ejecutar código desde el navegador si ocurre un error. **Solo para desarrollo.** En el servidor, siempre FLASK_DEBUG=0.

14.4 IP de los usuarios en auditoría

```
docker exec syscomcli_bd psql -U postgres -d sysclin_bd -c "SELECT accion, ip_origen, fecha_evento FROM auditoria_sistema ORDER BY fecha_evento DESC LIMIT 10"
```

- En desarrollo, con Docker Desktop, los accesos desde la propia PC aparecen como 172.x.x.1. Es normal.
- Por HTTPS la IP **no se puede falsificar**: nginx reemplaza el encabezado X-Forwarded-For que mande el cliente. Por el puerto 5005 sí se podría; por eso en el servidor se cierra.

14.5 Bloqueo de cuentas y límites de intentos

Nivel	Se activa con	Bloqueo	Se levanta
1	5 intentos fallidos	30 minutos	Solo, al vencer el tiempo
2	3 intentos fallidos más	1 hora	Solo, al vencer el tiempo
3	3 intentos fallidos más	**Indefinido**	**Solo un administrador**

- Un inicio de sesión correcto reinicia el contador al nivel 0.
- En cada fallo el usuario ve Contraseña incorrecta. Intentos restantes: N. Al bloquearse, le llega un **correo de aviso** si tiene uno vinculado.
- Mientras la cuenta está bloqueada, **ni la contraseña correcta deja entrar**.

Límite	Regla	Qué ve el usuario	Se levanta
Por IP (login)	10 fallos desde una misma IP en 15 min, sumando todos los usuarios	Demasiados intentos fallidos desde esta IP…	Solo, a los 15 min
Recuperación de contraseña	3 correos por cuenta en 60 min	El mensaje genérico de siempre, pero no se envía otro correo	Solo, a los 60 min
Código MFA	5 intentos por código	Debe pedir un código nuevo	Al pedir otro código

14.5.1 Desbloquear una cuenta desde la aplicación

- **Auditoría → Sesiones y usuarios →** botón **Desbloquear** en la fila del usuario, o
- **Usuarios →** detalle del usuario **→ Resetear intentos y desbloquear**.

La cuenta vuelve al **nivel 0**. Antes de desbloquear, revisar en Auditoría si los intentos fueron del propio usuario.

14.5.2 Consultas por consola

```
# Cuentas bloqueadas o con escalada activa
docker exec syscomcli_bd psql -U postgres -d sysclin_bd -c "SELECT usu_nick, nivel_escalada_bloqueo, usu_nro_intentos, motivo_bloqueo, bloqueado_hasta FROM usuarios WHERE fecha_bloqueo IS NOT NULL OR nivel_escalada_bloqueo > 0"

# Eventos de seguridad recientes
docker exec syscomcli_bd psql -U postgres -d sysclin_bd -c "SELECT fecha_evento, accion, host(ip_origen) AS ip, detalle FROM auditoria_sistema WHERE accion IN ('ACCOUNT_LOCKED','ACCOUNT_UNLOCKED','RATE_LIMIT') ORDER BY fecha_evento DESC LIMIT 20"
```

14.5.3 Desbloqueo de emergencia por consola

> **Nota:** Solo si **ningún administrador puede iniciar sesión** (por ejemplo, el único administrador quedó en el nivel 3). Reemplazar <usuario> y <tu_nombre>; el comando deja el registro en auditoría.

```
"UPDATE usuarios SET usu_nro_intentos=0, nivel_escalada_bloqueo=0, fecha_bloqueo=NULL,
bloqueado_hasta=NULL, motivo_bloqueo=NULL WHERE usu_nick='<usuario>'; INSERT INTO auditoria_sistema
(accion, detalle) VALUES ('ACCOUNT_UNLOCKED', 'Desbloqueo de emergencia por consola de <usuario>,
realizado por <tu_nombre>');" | docker exec -i syscomcli_bd psql -U postgres -d sysclin_bd -v ON_ERROR_STOP=1
```

Riesgo conocido: como el bloqueo es por cuenta, alguien que conozca un nombre de usuario puede provocar su bloqueo sin saber la contraseña. Ante bloqueos repetidos, revisar en Auditoría la IP de origen de los LOGIN_FAILED.

15. Auditoría y chequeo periódico

15.1 Qué se registra

En la tabla auditoria_sistema, con usuario, IP, fecha y detalle. Se consulta en Auditoría → pestaña **Eventos del sistema**.

Evento	Qué registra
LOGIN, LOGOUT, LOGIN_FAILED	Inicios, cierres e intentos fallidos de sesión
ACCOUNT_LOCKED, ACCOUNT_UNLOCKED	Bloqueo por intentos fallidos (con el nivel) y desbloqueo (con quién desbloqueó)
RATE_LIMIT	Una IP frenada en el login, o la recuperación de una cuenta frenada. Una vez por ventana, no en cada intento
PASSWORD_CHANGE	Cambios y reseteos de contraseña
RECORD_CREATE/UPDATE/DELETE, REPORT_VIEW/EXPORT	Operaciones sobre registros, consulta de reportes y su exportación a PDF

Además, accesos_sistema guarda cada intento de login con su resultado, IP y navegador (Auditoría → pestaña **Accesos y seguridad**).

15.2 Cambios en datos

Desde el 2026-10-19, cada alta, modificación y baja de las 40 tablas críticas (clínicas, agendamiento, ventas y seguridad) queda en auditoria_transacciones, con el **dato anterior y el nuevo**, el usuario, sus roles, la IP y la hora. Lo registra la base con un trigger; la aplicación solo puede leerlo, nunca modificarlo ni borrarlo. Las contraseñas y claves secretas se guardan como ***. Se consulta en Auditoría → pestaña **Cambios en datos**: el Administrador ve todo; el Superadministrador, todo menos lo clínico; Recepción, agendamiento; el Clínico, solo sus propios cambios; Ventas, solo cantidades.

15.3 Alertas e informe semanal

- **Alertas por correo**, cada 5 minutos, a los Administradores y Superadministradores activos con correo cargado: anulaciones (facturas, notas de crédito y débito, cobranzas) y cambios hechos fuera del horario de atención de la empresa (Referenciales → Empresa). Cada uno recibe solo lo que su rol puede ver. Quedan registradas como ALERTA_ENVIADA.
- **Informe semanal en PDF**, los lunes a las 07:00, con la semana anterior; también se descarga con el botón **Informe semanal (PDF)** de Auditoría. Queda registrado como INFORME_SEMANAL.

15.4 Chequeo de seguridad periódico

Una vez por mes, y antes de una entrega o despliegue.

#	Qué comprobar	Cómo	Esperado
1	Los contenedores están corriendo	docker ps --filter name=syscomcli	4 contenedores Up; la base, healthy
2	HTTPS activo y HTTP redirige	Manual de infraestructura, capítulo «HTTPS, red y despliegue», "Comprobar HTTPS"	301 a https; TLS 1.2/1.3; encabezados presentes

#	Qué comprobar	Cómo	Esperado
3	El certificado no está por vencer (servidor)	Manual de infraestructura, capítulo «HTTPS, red y despliegue», fecha de vencimiento	Más de 30 días restantes
4	El backup automático funciona	`docker logs syscomcli_backup --tail 5`	`Backup creado` de las últimas 24 h
5	Los backups se pueden restaurar	Prueba de restauración	`RESTAURACION OK`
6	No hay backups sin cifrar	`Get-ChildItem backups -Filter *.dump`	Ningún archivo
7	La app no usa el superusuario	`docker exec syscomcli_app printenv DB_USER`	`sysclin_app`
8	Los permisos de la app son mínimos	Manual de infraestructura, capítulo «Base de datos»	Los 3 `ERROR`
9	La clave por defecto no sirve	Manual de infraestructura, capítulo «Base de datos»	`password authentication failed`
10	La cookie es segura	Capítulo Seguridad de la aplicación	`HttpOnly`, `SameSite=Lax` (y `Secure` en el servidor)
11	Accesos sospechosos	**Auditoría → Accesos y seguridad**	Revisar ráfagas de `LOGIN_FAILED` desde una misma IP
11b	Cambios fuera de lo común	Informe semanal de auditoría (correo del lunes o botón en Auditoría)	Revisar anulaciones y cambios fuera de horario
12	Bloqueos y límites del mes	Consultas del capítulo Seguridad de la aplicación	Revisar `ACCOUNT_LOCKED` repetidos y `RATE_LIMIT` desde IP desconocidas
13	Dependencias sin vulnerabilidades	Manual de infraestructura, capítulo «Gestión de vulnerabilidades»	`No known vulnerabilities found`
14	La clave privada está en custodia	Revisar que no esté en la PC ni en el servidor	Solo en USB o gestor de contraseñas
15	Usuarios activos que ya no trabajan en la clínica	Pantalla **Usuarios**	Ninguno: desactivar los que correspondan

16. Riesgos aceptados y normativa

16.1 Riesgos aceptados

Riesgo	Por qué se acepta	Mitigación
En desarrollo, los puertos 5005, 5434 y 5680 están abiertos a la red local	Se trabaja con varios proyectos en paralelo	En el servidor se cierran; en desarrollo no hay datos reales de pacientes
Un tercero puede bloquear una cuenta ajena con intentos fallidos	Es el costo del bloqueo por cuenta	El bloqueo indefinido requiere un administrador; queda auditado con la IP de origen
Dentro del contenedor de la base, las conexiones locales no piden contraseña	Requiere acceso a Docker, que equivale a ser administrador del equipo	El acceso al servidor queda restringido al administrador
Los backups están en el mismo disco que la base	Infraestructura de un solo equipo	Están cifrados; se recomienda una copia semanal fuera del equipo
Sin Content-Security-Policy	Las plantillas usan scripts en línea y CDNs	Mejora futura

16.2 Pendiente de incorporar

- Auditoría de cambios en los datos con el valor anterior y el nuevo, y registros de auditoría que no se puedan modificar ni borrar.
- Vistas y procedimientos almacenados: qué hay, cómo se usan y cómo probarlos.

16.3 Normativa de referencia

ISO/IEC 27001 (gestión de la seguridad de la información) y las buenas prácticas de OWASP se usan como **referencia**, no como certificación. El tratamiento de datos de salud se rige por la legislación paraguaya de protección de datos personales vigente.

Anexo A. Preguntas frecuentes

Pregunta	Respuesta
¿Por qué mi contraseña tiene que cumplir tantas reglas?	Porque una contraseña con mayúsculas, minúsculas, números y símbolos es mucho más difícil de adivinar. Una frase corta con un número y un símbolo es fácil de recordar y difícil de descubrir
¿Por qué el sistema me pide cambiar la contraseña la primera vez?	Porque la temporal la eligió el administrador. Al cambiarla, la definitiva solo la conoce usted
¿El administrador puede ver mi contraseña?	No. Se guarda cifrada y nadie puede verla
¿Tengo que cambiar la contraseña cada cierto tiempo?	Sí. Vence cada 90 días y el sistema se lo avisa al ingresar
¿Por qué me pide un código si ya escribí mi contraseña?	Porque se necesitan las dos cosas: lo que usted sabe (la contraseña) y lo que usted tiene (su correo). Así una contraseña robada, por sí sola, no alcanza
Cambié de correo, ¿qué hago?	Avise al administrador: puede revocar su verificación en dos pasos para que usted vincule el correo nuevo
¿Por qué tengo que ingresar de nuevo cada tanto?	Porque la sesión se cierra tras 20 minutos sin uso, para que nadie use su sesión abierta
Anulé algo por error, ¿se puede recuperar?	Avise al administrador. Como nada se borra, el registro anulado y su historial siguen en el sistema

Anexo B. Glosario

Palabra	Significado
Anular	Dejar sin efecto un documento (factura, orden, cobranza) indicando el motivo. El documento no se borra: queda en el historial como anulado
Auditoría	Registro automático de quién hizo cada cambio en el sistema y cuándo
Bloqueo	Impedimento para entrar después de varios intentos fallidos con la contraseña: 30 minutos, luego 1 hora y luego hasta que un administrador lo levante
Cifrado	Transformar la información para que solo pueda leerla quien tiene la clave
Copia de respaldo	Copia de toda la información, guardada aparte para recuperarla si algo falla
Dispositivo confiable	Equipo en el que ya se verificó el código: el sistema lo recuerda 60 días y no vuelve a pedirlo ahí
Rol	Conjunto de permisos según la función de la persona: Recepción, Clínico, Ventas, Administrador o Superadministrador
Sesión	El tiempo que pasa desde que usted ingresa al sistema hasta que sale
Verificación en dos pasos	Ingreso con la contraseña más un código enviado al correo

Anexo C. Contactos

Complete y tenga a mano:

Rol	Nombre	Teléfono	Correo
Administrador del sistema			
Superadministrador			
Soporte técnico			